Module 5

Vulnerability Analysis

Vulnerability analysis is the process of identifying, classifying, and prioritizing security weaknesses in a system to assess the risk and impact of potential cyberattacks. This involves systematically reviewing a system's software, hardware, and network components to find flaws that malicious actors could exploit to gain unauthorized access, steal data, or disrupt services. The goal is to provide actionable insights for strengthening security defenses and mitigating threats before they can be exploited.

★ Performed Vulnerability Research with Vulnerability Scoring Systems and Databases using Tenable Nessus:

How it works:

Nessus performs vulnerability analysis by scanning target systems and identifying weaknesses through a vast, regularly updated database of known vulnerabilities. It works by checking open ports for services, then using its plugins to test those services for vulnerabilities, misconfigurations, and missing patches. The process involves setting up a scan, running it against targets (either unauthenticated or with credentials for a deeper look), and then reviewing the detailed report, which categorizes findings by severity and provides remediation advice.

Not secure https://localhost:8834/#/scans/reports/5/hosts/2/vulnerabilities

tenable Nessus Essentials | Scans | Settings | Omkar

FOLDERS
- My Scans
- All Scans
- Trash

RESOURCES
- Policies
- Plugin Rules

Tenable News

Reinvigorating Federal Cybersecurity Post Shutdown...

Test / certifiedhacker.com

‹ Back to Hosts

Configure

Vulnerabilities 5

Filter | Search Vulnerabilities | 5 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	3
MIXED	...	...	...	DNS (Multiple Issues)	DNS	4
INFO				Nessus SYN scanner	Port scanners	23
INFO				Service Detection	Service detection	5
INFO				Host Fully Qualified Domain Name (FQDN) Resol...	General	1

Host Details

IP: 162.241.216.11
DNS: certifiedhacker.com
Start: Today at 12:22 PM
Auth: N/A

Vulnerabilities

Critical
High
Medium
Low
Info

23°C Sunny | Search | ENG IN | 12:32 03-12-2025

how vulnerability analysis works thro

Not secure https://localhost:8834/#/scans/reports/5/hosts/2/vulnerabilities

tenable Nessus Essentials | Scans | Settings | Omkar

FOLDERS
- My Scans
- All Scans
- Trash

RESOURCES
- Policies
- Plugin Rules

Tenable News

Exposure Management Vs. Siloed Security Tools: 4 W...

Read More

MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	3
MIXED	...	...	...	DNS (Multiple Issues)	DNS	4
INFO	...	...	...	SSH (Multiple Issues)	Misc.	2
INFO	...	...	...	SSH (Multiple Issues)	Service detection	2
INFO	...	...	...	TLS (Multiple Issues)	Misc.	2
INFO				Nessus SYN scanner	Port scanners	23
INFO				Service Detection	Service detection	22
INFO				SSL / TLS Versions Supported	General	5
INFO				HTTP Methods Allowed (per directory)	Web Servers	3
INFO				SMTP Server Detection	Service detection	3
INFO				POP Server Detection	Service detection	2
INFO				Service Detection (HELP Request)	Service detection	2
INFO				SMTP Service STARTTLS Command Support	SMTP problems	2
INFO				FTP Server Detection	Service detection	1
INFO				FTP Service AUTH TLS Command Support	FTP	1
INFO				Host Fully Qualified Domain Name (FQDN) Res...	General	1

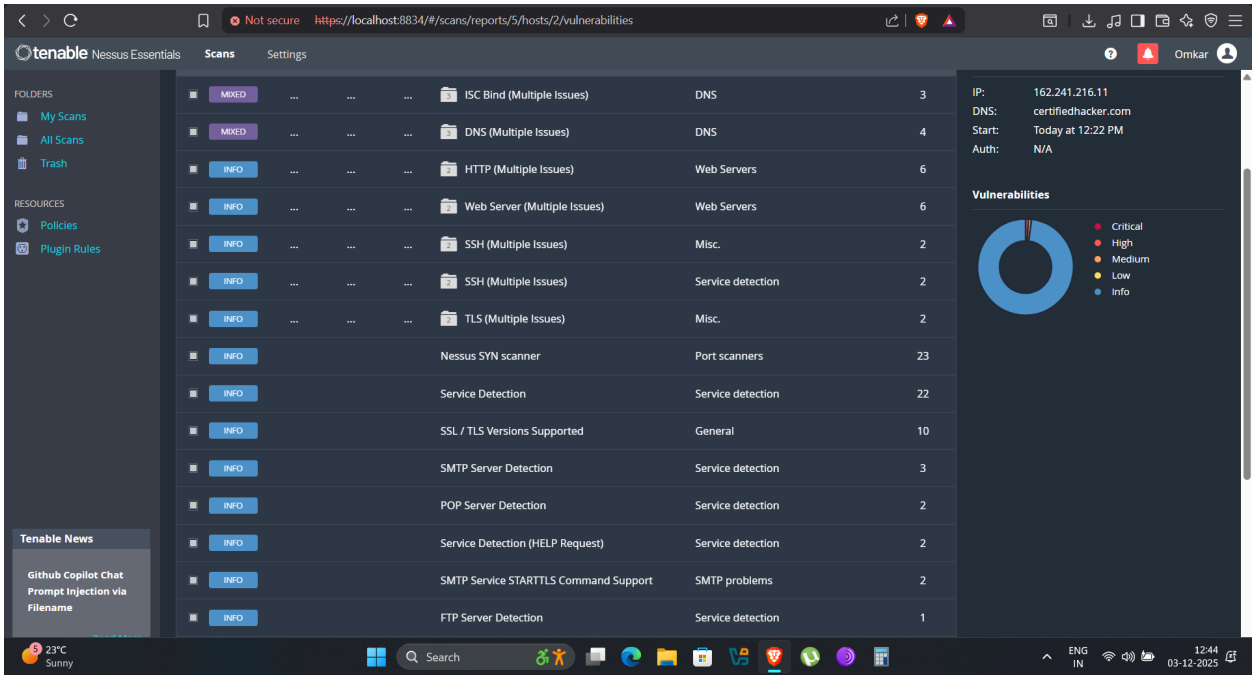
IP: 162.241.216.11
DNS: certifiedhacker.com
Start: Today at 12:22 PM
Auth: N/A

Vulnerabilities

Critical
High
Medium
Low
Info

★ Performed Vulnerability Research in Common Weakness Enumeration(CWE):

Performed Vulnerability research in Common Weakness Enumeration (CWE) using Nessus, first configured and run a vulnerability scan in Nessus to identify weaknesses on a target system. Then, used the scan results to research the vulnerabilities, mapping them to their corresponding CWE identifiers to understand their nature and categorization. Finally, use the CWE database to gather detailed information about these specific weaknesses to inform remediation efforts.



★ Performed Vulnerability Assessment using various Vulnerability Assessment Tools:

Here is a brief overview of the tools you mentioned and their general uses:

Nikto: An open-source web server scanner that performs comprehensive tests against web servers for multiple items, including identifying potential security risks, dangerous files/CGIs, outdated server software, and other configuration issues. It's widely used for initial, quick assessments.

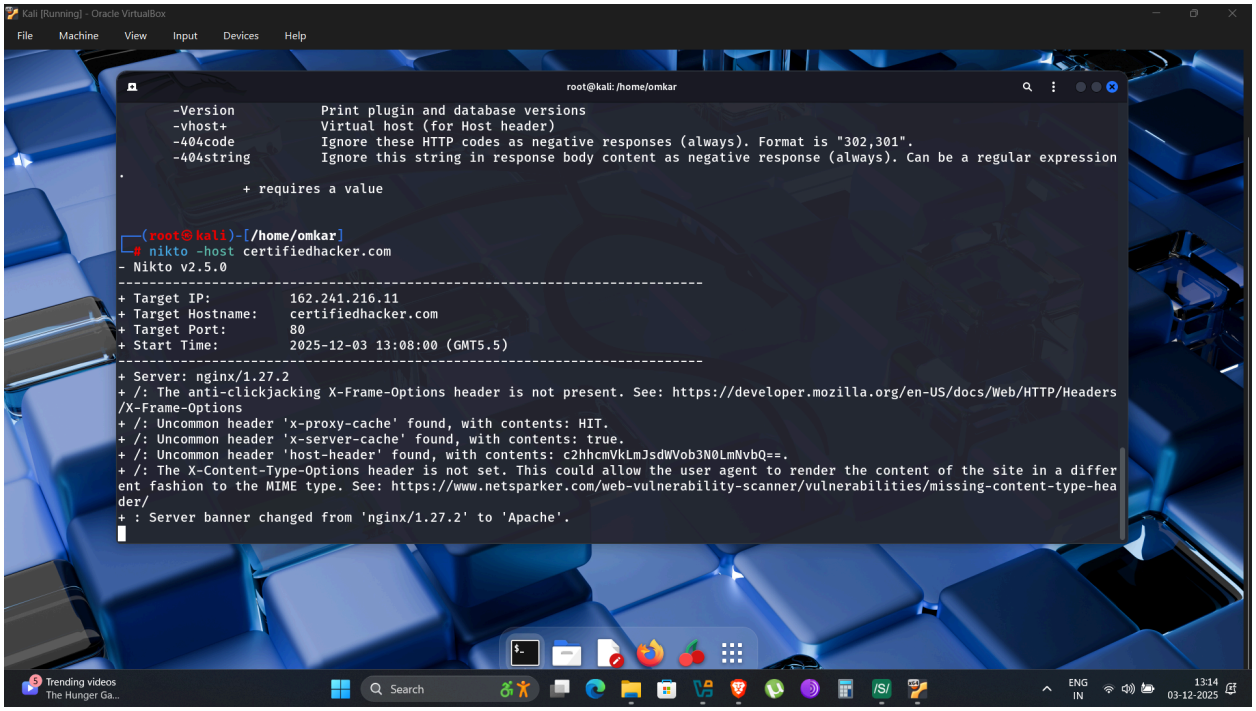
Acunetix: A commercial, comprehensive web application security testing solution. It can automatically detect over 7,000 vulnerabilities, including common ones like SQL injection and cross-site scripting (XSS), and provides detailed reports and remediation guidance.

SmartScanner: This is likely referencing one of several niche or potentially proprietary scanning tools, as the

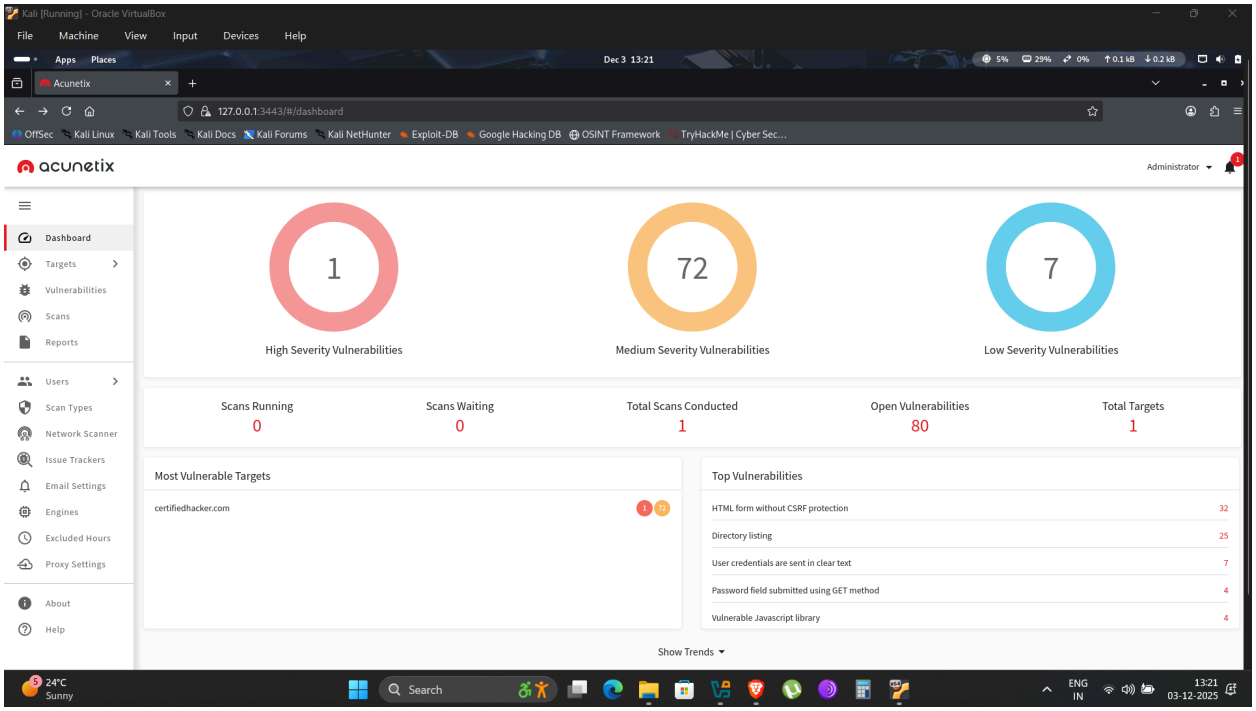
name is less universally known than the others. Many commercial security suites use "smart scanning" features that leverage machine learning or advanced heuristics to identify vulnerabilities.

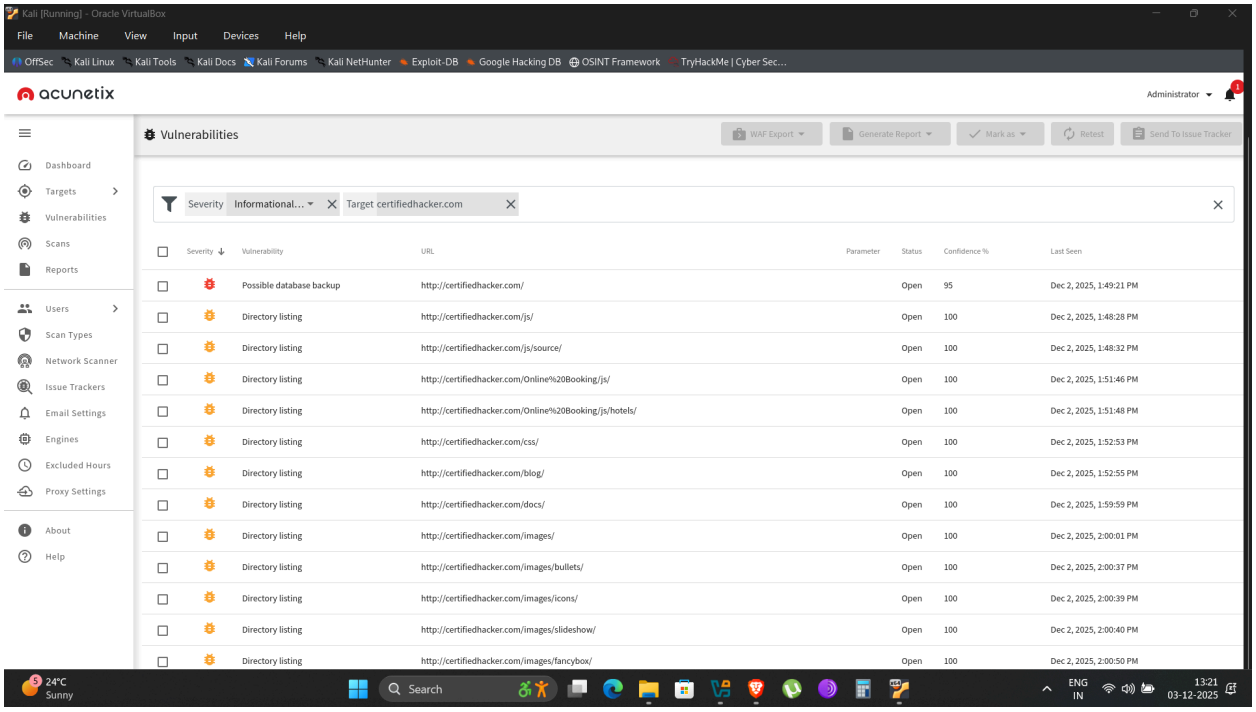
Performing vulnerability assessments is a critical step in identifying security weaknesses in systems and applications, allowing organizations to remediate these issues before they can be exploited by malicious actors. The next steps typically involve analyzing the scan results, prioritizing vulnerabilities based on risk, and developing a remediation plan.

Nikto:

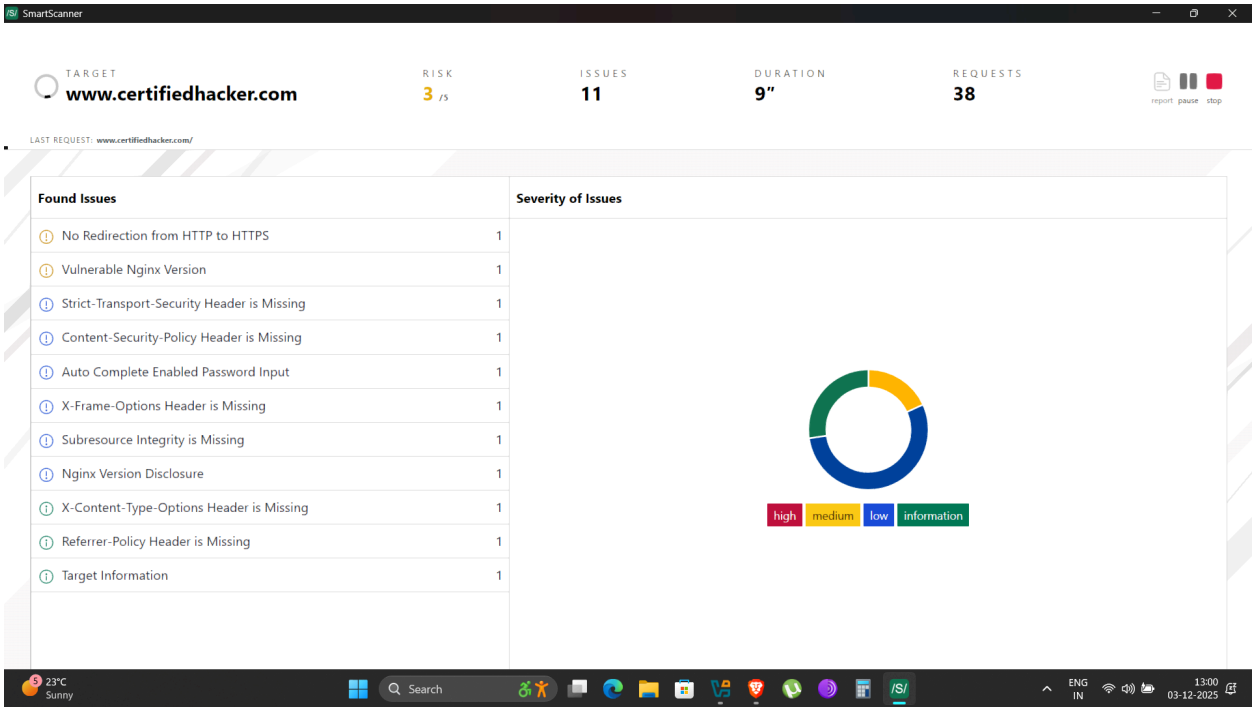


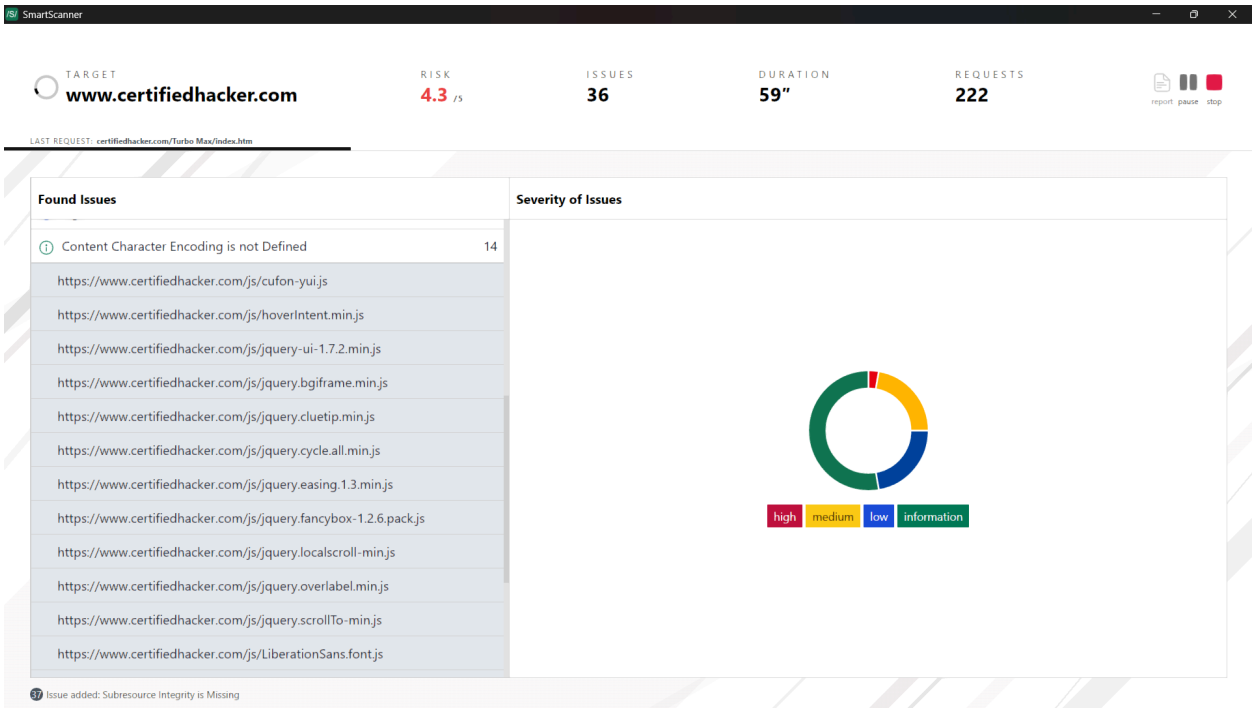
Acunetix:

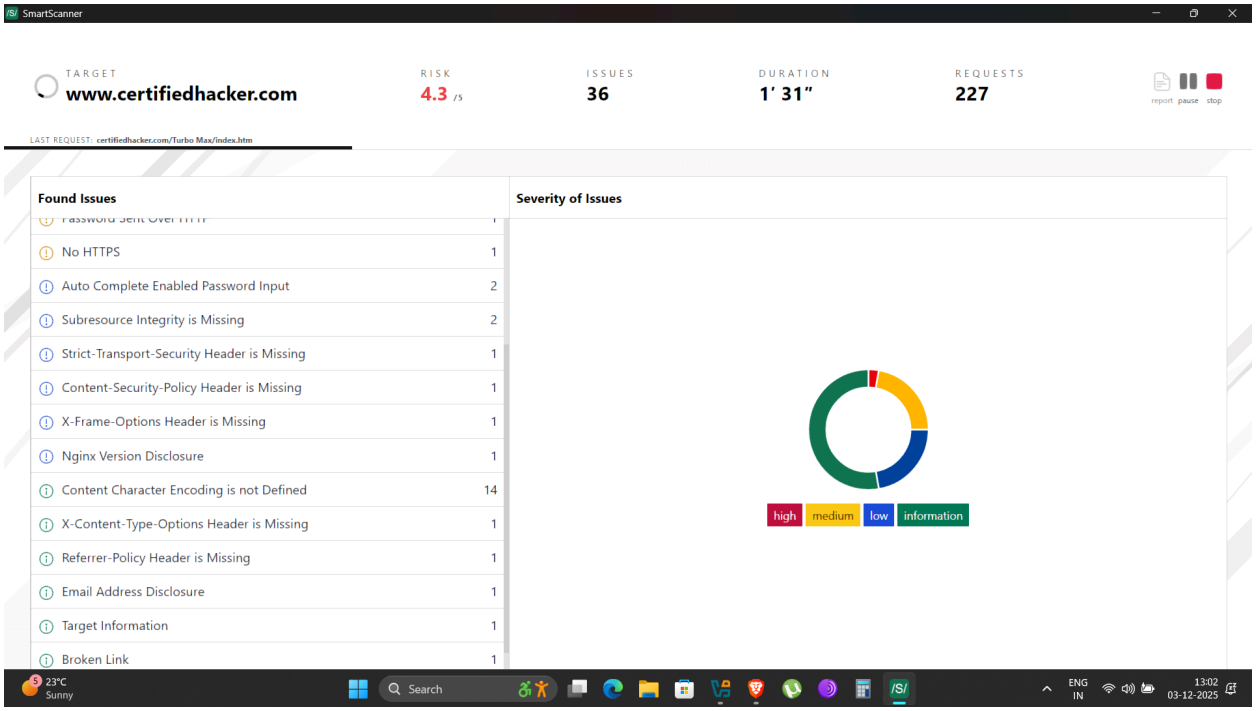

Kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Apps Places
Dec 3 13:21
Acunetix
127.0.0.1:3443/#/dashboard
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OSINT Framework TryHackMe | Cyber Sec...
acunetix
Administrator
Dashboard
Targets
Vulnerabilities
Scans
Reports
Users
Scan Types
Network Scanner
Issue Trackers
Email Settings
Engines
Excluded Hours
Proxy Settings
About
Help
1
High Severity Vulnerabilities
72
Medium Severity Vulnerabilities
7
Low Severity Vulnerabilities
Scans Running 0
Scans Waiting 0
Total Scans Conducted 1
Open Vulnerabilities 80
Total Targets 1
Most Vulnerable Targets
certifiedhacker.com
Top Vulnerabilities
HTML form without CSRF protection 32
Directory listing 25
User credentials are sent in clear text 7
Password field submitted using GET method 4
Vulnerable Javascript library 4
Show Trends
24°C Sunny
Search
ENG IN
13:21 03-12-2025


Kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OSINT Framework TryHackMe | Cyber Sec...
acunetix
Administrator
Vulnerabilities
WAF Export
Generate Report
Mark as
Retest
Send To Issue Tracker
Severity Informational...
Target certifiedhacker.com
Severity Vulnerability URL Parameter Status Confidence % Last Seen
Possible database backup http://certifiedhacker.com/ Open 95 Dec 2, 2025, 1:49:21 PM
Directory listing http://certifiedhacker.com/js/ Open 100 Dec 2, 2025, 1:48:28 PM
Directory listing http://certifiedhacker.com/js/source/ Open 100 Dec 2, 2025, 1:48:32 PM
Directory listing http://certifiedhacker.com/Online%20Booking/js/ Open 100 Dec 2, 2025, 1:51:46 PM
Directory listing http://certifiedhacker.com/Online%20Booking/js/hotels/ Open 100 Dec 2, 2025, 1:51:48 PM
Directory listing http://certifiedhacker.com/css/ Open 100 Dec 2, 2025, 1:52:53 PM
Directory listing http://certifiedhacker.com/blog/ Open 100 Dec 2, 2025, 1:52:55 PM
Directory listing http://certifiedhacker.com/docs/ Open 100 Dec 2, 2025, 1:59:59 PM
Directory listing http://certifiedhacker.com/images/ Open 100 Dec 2, 2025, 2:00:01 PM
Directory listing http://certifiedhacker.com/images/bullets/ Open 100 Dec 2, 2025, 2:00:37 PM
Directory listing http://certifiedhacker.com/images/icons/ Open 100 Dec 2, 2025, 2:00:39 PM
Directory listing http://certifiedhacker.com/images/slideshow/ Open 100 Dec 2, 2025, 2:00:40 PM
Directory listing http://certifiedhacker.com/images/fancybox/ Open 100 Dec 2, 2025, 2:00:50 PM
24°C Sunny
Search
ENG IN
13:21 03-12-2025

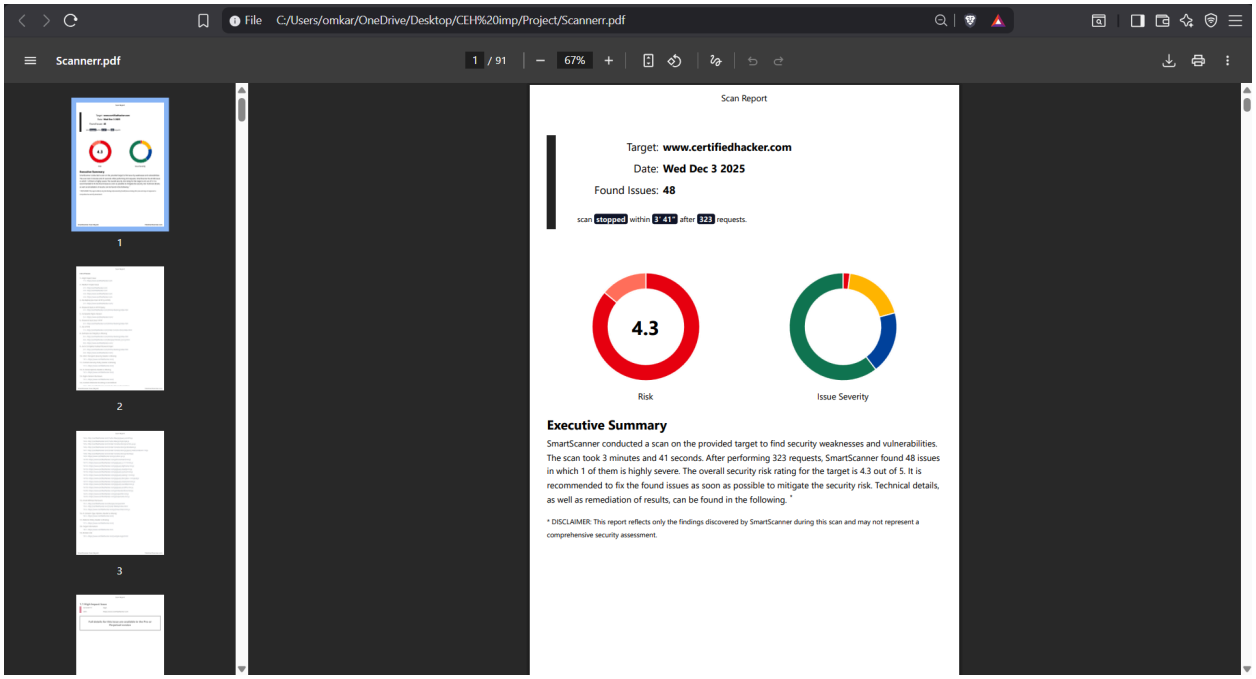
SmartScanner:






SmartScanner
TARGET
www.certifiedhacker.com
RISK
4.3 /5
ISSUES
36
DURATION
1' 31"
REQUESTS
227
report
pause
stop
LAST REQUEST: certifiedhacker.com/Turbo Max/index.htm
Found Issues
Severity of Issues
No HTTPS 1
Auto Complete Enabled Password Input 2
Subresource Integrity is Missing 2
Strict-Transport-Security Header is Missing 1
Content-Security-Policy Header is Missing 1
X-Frame-Options Header is Missing 1
Nginx Version Disclosure 1
Content Character Encoding is not Defined 14
X-Content-Type-Options Header is Missing 1
Referrer-Policy Header is Missing 1
Email Address Disclosure 1
Target Information 1
Broken Link 1
high
medium
low
information
23°C
Sunny
Search
ENG
IN
13:02
03-12-2025

Report:


File C:/Users/omkar/OneDrive/Desktop/CEH%20imp/Project/Scannerr.pdf
Scannerr.pdf
1 / 91
67%
Scan Report
Target: www.certifiedhacker.com
Date: Wed Dec 3 2025
Found Issues: 48
scan stopped within 3' 41" after 323 requests.
4.3
Risk
Issue Severity
Executive Summary
SmartScanner conducted a scan on the provided target to find security weaknesses and vulnerabilities. The scan took 3 minutes and 41 seconds. After performing 323 requests, SmartScanner found 48 issues in which 1 of them is highly severe. The overall security risk rating for the target is 4.3 out of 5. It is recommended to fix the found issues as soon as possible to mitigate the security risk. Technical details, as well as remediation of results, can be found in the following. *
* DISCLAIMER: This report reflects only the findings discovered by SmartScanner during this scan and may not represent a comprehensive security assessment.

File C:/Users/omkar/OneDrive/Desktop/CEH%20imp/Project/Scannerr.pdf

Scannerr.pdf 2 / 91 67%

Scan Report

List of Issues

1– High Impact Issue
- 1.1– https://www.certifiedhacker.com

2– Medium Impact Issue
- 2.1– http://certifiedhacker.com
- 2.2– http://certifiedhacker.com
- 2.3– https://www.certifiedhacker.com
- 2.4– https://www.certifiedhacker.com

3– No Redirection from HTTP to HTTPS
- 3.1– https://www.certifiedhacker.com/

4– Password Sent in HTTP Query
- 4.1– http://certifiedhacker.com/Online Booking/index.htm

5– Vulnerable Nginx Version
- 5.1– https://www.certifiedhacker.com/

6– Password Sent Over HTTP
- 6.1– http://certifiedhacker.com/Online Booking/index.htm

7– No HTTPS
- 7.1– http://certifiedhacker.com/Under Construction/index.html

8– Subresource Integrity is Missing
- 8.1– http://certifiedhacker.com/Online Booking/index.htm
- 8.2– http://certifiedhacker.com/Recipes/Chicken_Curry.html
- 8.3– https://www.certifiedhacker.com/

9– Auto Complete Enabled Password Input
- 9.1– http://certifiedhacker.com/Online Booking/index.htm
- 9.2– https://www.certifiedhacker.com/

10– Strict-Transport-Security Header is Missing
- 10.1– https://www.certifiedhacker.com/

11– Content-Security-Policy Header is Missing
- 11.1– https://www.certifiedhacker.com/

12– X-Frame-Options Header is Missing
- 12.1– https://www.certifiedhacker.com/

13– Nginx Version Disclosure
- 13.1– https://www.certifiedhacker.com/

14– Content Character Encoding is not Defined

File C:/Users/omkar/OneDrive/Desktop/CEH%20imp/Project/Scannerr.pdf

Scannerr.pdf 3 / 91 67%

Scan Report

- 14.3– http://certifiedhacker.com/Turbo Max/js/jquery.scrollTo.js
- 14.4– http://certifiedhacker.com/Turbo Max/js/myScripts.js
- 14.5– http://certifiedhacker.com/Under Construction/js/cufon-yui.js
- 14.6– http://certifiedhacker.com/Under Construction/js/droidsans.js
- 14.7– http://certifiedhacker.com/Under Construction/js/jquery.lwtCountdown-1.0.js
- 14.8– http://certifiedhacker.com/Under Construction/js/tooltip.js
- 14.9– https://www.certifiedhacker.com/js/cufon-yui.js
- 14.10– https://www.certifiedhacker.com/js/hoverIntent.min.js
- 14.11– https://www.certifiedhacker.com/js/jquery-ui-1.7.2.min.js
- 14.12– https://www.certifiedhacker.com/js/jquery.bgiframe.min.js
- 14.13– https://www.certifiedhacker.com/js/jquery.cluetip.min.js
- 14.14– https://www.certifiedhacker.com/js/jquery.cycle.all.min.js
- 14.15– https://www.certifiedhacker.com/js/jquery.easing.1.3.min.js
- 14.16– https://www.certifiedhacker.com/js/jquery.fancybox-1.2.6.pack.js
- 14.17– https://www.certifiedhacker.com/js/jquery.localscroll-min.js
- 14.18– https://www.certifiedhacker.com/js/jquery.overlabel.min.js
- 14.19– https://www.certifiedhacker.com/js/jquery.scrollTo-min.js
- 14.20– https://www.certifiedhacker.com/js/LiberationSans.font.js
- 14.21– https://www.certifiedhacker.com/js/superfish.min.js
- 14.22– https://www.certifiedhacker.com/js/supersubs.min.js

15– Email Address Disclosure
- 15.1– http://certifiedhacker.com/Recipes/recipes.html
- 15.2– http://certifiedhacker.com/Social Media/index.html
- 15.3– https://www.certifiedhacker.com/js/hoverIntent.min.js

16– X-Content-Type-Options Header is Missing
- 16.1– https://www.certifiedhacker.com/

17– Referrer-Policy Header is Missing
- 17.1– https://www.certifiedhacker.com/

18– Target Information
- 18.1– https://www.certifiedhacker.com

19– Broken Link
- 19.1– https://www.certifiedhacker.com/sample-login.html

File C:/Users/omkar/OneDrive/Desktop/CEH%20imp/Project/Scannerr.pdf

Scannerr.pdf 4 / 91 67%

Scan Report

1.1 High Impact Issue

SEVERITY	High
URL	https://www.certifiedhacker.com

Full details for this issue are available in the Pro or Perpetual version

File C:/Users/omkar/OneDrive/Desktop/CEH%20imp/Project/Scannerr.pdf

Scannerr.pdf 5 / 91 67%

Scan Report

2.1 Medium Impact Issue

SEVERITY	Medium
URL	http://certifiedhacker.com

Full details for this issue are available in the Pro or Perpetual version

Air: Moderate Now Search ENG IN 13:12 03-12-2025